AWS Certified DevOps Engineer – Professional（DOP-C02）　タスク 6.3　#22

セキュリティの監視と監査

GuardDuty（委任管理者・全リージョン・抑制ルール・S3 Protection・Runtime Monitoring・Malware Protection・EventBridge）・Inspector・Detective、Security Hub（標準・ASFF・クロスリージョン集約・中央設定）・Security Lake（OCSF）・Config アグリゲータ・侵害された認証情報への対応、組織の証跡・ログファイルの整合性の検証・CloudTrail のアラーム・ドリフト検出・Audit Manager・Artifact

各ページの下に、根拠にした資料（AWS の DOP-C02 試験ガイド、GuardDuty・Inspector・Detective・Security Hub・Security Lake・Config・CloudTrail・CloudFormation・Audit Manager・Artifact の各ガイド、AWS 管理ポリシーリファレンス）を書いた。『』の中はドキュメントの原文どおり

第1章

脅威と脆弱性を見つける

動きを見る GuardDuty、弱点を見る Inspector、原因を調べる Detective。

GuardDuty のしくみ

CloudTrail 管理イベント・VPC フローログ・DNS ログ
自分で有効にしなくても GuardDuty が独立して取り込む

↓ 脅威インテリジェンス＋機械学習

検出結果（Finding）
例：InstanceCredentialExfiltration＝インスタンスロールの認証情報が外で使われた

↓ 自動で送られる

EventBridge → SNS・Lambda・Step Functions
重要度で絞って通知・隔離

設定	ポイント
委任管理者	組織のメンバーを自動で有効化（新しいアカウントも）
リージョン	リージョンごと。使っていないリージョンも有効に
抑制ルール	正当な動きの結果を自動でアーカイブ

> GuardDuty を止める・EventBridge のルールを消す は誤答の定番。

出典：Amazon GuardDuty とは『こうしたデータソースには、AWS CloudTrail 管理イベント、VPC フローログ (Amazon EC2 インスタンスから生成)、DNS ログなどがあります。』／AWS Organizations／抑制ルール／EventBridge／IAM 検出結果タイプ

保護プランと Inspector・Detective

見つけたいもの	使うもの	ポイント
S3 の持ち出し・破棄	GuardDuty S3 Protection	S3 のデータイベントを見る（Macie は機密データの場所）
コンテナ・OS の中の動き	GuardDuty Runtime Monitoring	エージェントでプロセス・ファイル・接続
EC2 のマルウェア	GuardDuty Malware Protection for EC2	エージェントなし、EBS のスナップショットでスキャン
ソフトの脆弱性（CVE）	Amazon Inspector	EC2・ECR・Lambda。変化に応じて自動で再スキャン。SSM Agent か EBS スナップショット
根本原因の調査	Amazon Detective	機械学習・統計・グラフで関係をたどる

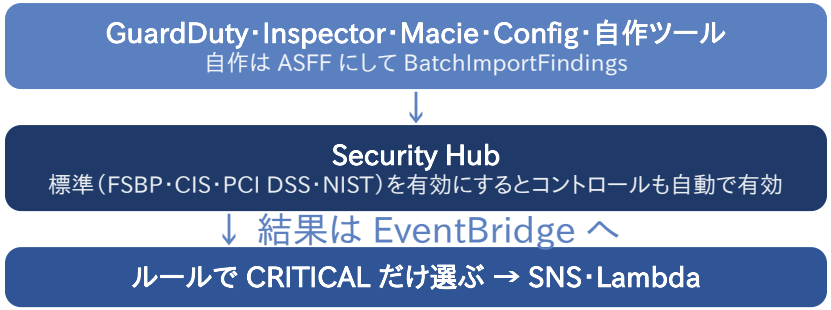
出典：S3 Protection／Runtime Monitoring『Runtime Monitoring では、GuardDuty セキュリティエージェントを使用して、ファイルアクセス、プロセス実行、コマンドライン引数、ネットワーク接続などのランタイムアクティビティを可視化します。』／Malware Protection for EC2／Amazon Inspector とは／自動スキャンタイプ／Amazon Detective とは

第2章

まとめて見て自動で対応する

集めるのは Security Hub、貯めるのは Security Lake、動かすのは EventBridge。

Security Hub と集約



やりたいこと	使うもの
全リージョンを 1 か所で	ホームリージョン+リンクされたリージョン
組織全体の設定を 1 か所で	中央設定（委任管理者・OU ごと）
ログを長く貯めて分析	Security Lake（OCSF・Parquet・自分の S3）
全アカウントの Config 準拠	Config のアグリゲータ

出典：Security Hub CSPM の概要／セキュリティ標準『標準を有効にすると、Security Hub CSPM は、その標準に適用されるすべてのコントロールを自動的に有効化します。』／ASFF／クロスリージョン集約／中央設定／EventBridge／Security Lake／Config のデータ集約

侵害された認証情報への対応

① 関係する IAM エンティティと使われた API を特定

↓

② 権限を確かめ、正当な利用か確認

↓ 正当でない

③ キーを無効にしてローテーション、不正な操作を調べる

サイン	意味
AWSCompromisedKeyQuarantineV3	AWS が公開されたキーを見つけて付けた。一部の操作を拒否
InstanceCredentialExfiltration	インスタンスロールの認証情報が外で使われた → セッションを取り消す

> アカウントを閉じる・全ユーザーを消す はやりすぎ。

出典：侵害された可能性のある AWS 認証情報の修正／AWSCompromisedKeyQuarantineV3『IAM ユーザーの認証情報 AWS が侵害または公開された場合に によって適用される特定のアクションへのアクセスを拒否します。』／IAM 検出結果タイプ

第3章

監査のための記録と証拠

残す・守る・知らせる・証拠を集める。

記録と証拠の道具

やりたいこと	使うもの	ポイント
組織の全操作を記録	組織の証跡	メンバーは止められない・新アカウントも自動
ログの改ざんがない証明	ログファイルの整合性の検証	SHA-256 のハッシュ＋RSA 署名のダイジェスト
ルートのサインインを即通知	CloudWatch Logs のメトリクスフィルター＋アラーム	EventBridge のルールでもよい
手で変えられた設定	CloudFormation のドリフト検出	変更セットは「これからの変更」
監査の証拠を自動で集める	AWS Audit Manager	自分の環境の証拠
AWS の SOC・ISO レポート	AWS Artifact	AWS 側の統制の証明

出典：組織の証跡の作成『組織の証跡では、組織内の管理アカウントとすべてのメンバーアカウントのイベントが記録されます。』／整合性の検証／CloudWatch Logs によるモニタリング／ドリフト検出／Audit Manager／Artifact

本番での問われ方

ねらい	見るところ
見つける	GuardDuty（ログは自分で有効にしなくてよい・全リージョン・委任管理者・抑制ルール）と保護プラン、Inspector、Detective の役割の違い
まとめる	Security Hub の標準・ASFF・クロスリージョン集約・中央設定、Security Lake の OCSF、Config アグリゲータ
対応する	結果 → EventBridge → SNS・Lambda、侵害された認証情報の手順
監査	組織の証跡、整合性の検証、メトリクスフィルターのアラーム、ドリフト検出、Audit Manager と Artifact の違い

出典：AWS Certified DevOps Engineer - Professional (DOP-C02) 試験ガイド タスク 6.3